

EGR6301 — Етичний хакінг

Лабораторна робота 3: Перша керована експлуатація

Тиждень 3, Модуль I: Основи

Тривалість: 90 хвилин. .

Максимальний бал: 100 (Core: 60, Advanced: 20, PhD Extension: 20)

Інструменти: Kali Linux VM, Metasploitable 2 VM, VirtualBox з Host-Only мережею

Передумова: заповнена карта сервісів з Lab 2, де vsftpd 2.3.4 ідентифіковано на порту 21

Довідка CVE: опис CVE-2011-2523, наданий викладачем

Здача: один PDF зі скріншотами, назва Lab3_Прізвище_Група.pdf

Викладач: Тетяна Василівна Бабенко, д.т.н., професор

ДЛЯ ЗДАЧІ ЛАБОРАТОРНОЇ: Виконайте Частини 1, 2 та 3 (Core).

Частини 1 по 3 складають обов'язкове завдання для всіх студентів і розраховані на 90-хвилинну сесію. Частина 4 є необов'язковим розширенням для студентів із сильнішою технічною підготовкою, які завершать Core раніше. Частина 5 — аналітичне розширення PhD-рівня, яке може бути здане протягом 48 годин після заняття.

Цілі навчання

Ця лабораторна об'єднує кілька напрямків з Лекції 3. Ви почнете з визначення базової термінології, на яку спирається індустрія, а саме CVE, CVSS та Impact, і вам потрібно буде пояснити, чому серйозність і впевненість це не одне й те саме. Далі ви дослідите CVE-2011-2523 та сформулюєте, чим ця вразливість є supply-chain compromise, а не звичайним програмним дефектом.

Перш ніж торкнутися Metasploit, ви заповните Go/No-Go чек-лист, який змушує перевірити авторизацію, версію, очікувану поведінку та план збору доказів. Лише після цього ви виконаєте саму експлуатацію, дотримуючись протоколу мінімального збору доказів з Лекції 3. Фінальним продуктом є професійна знахідка (Finding) з усіма п'ятьма компонентами, написана так, ніби її читатиме СТО клієнта.

Рівні складності

Рівень Core охоплює Частини 1 по 3 і є обов'язковим для всіх студентів. За рівномірного темпу роботи він займе приблизно 70 хвилин. Рівень Advanced у Частині 4 є необов'язковим і призначений лише для тих, хто завершить Core із запасом часу. PhD Extension у Частині 5 розрахований на студентів магістратури та аспірантури, яким потрібна аналітична глибина за межами стандартної лабораторної, і його можна здати після заняття.

Частина 1: Ключові поняття та CVE-дослідження (Core) (20 балів, приблизно 20 хвилин)

Виконайте цю частину до відкриття Metasploit. Використовуйте довідку CVE від викладача. Пишіть одне-два точних речення на підпитання, якщо завдання не вказує інакше.

Завдання 1.1: Визначення CVE, CVSS та Impact (6 балів)

Почніть з пояснення своїми словами, що таке CVE, хто відповідає за присвоєння CVE-номерів і де ці записи публікуються. Потім опишіть, що саме вимірює CVSS, і запишіть шкалу оцінювання, вказавши, які діапазони відповідають рівням Low, Medium, High та Critical.

Тепер розгляньте вразливість з оцінкою CVSS 10.0. Чи гарантує це число, що exploit спрацює проти вашої конкретної цілі? Поясніть різницю між серйозністю та впевненістю так, щоб це було зрозуміло колезі, який ніколи не писав звіт пентесту.

Нарешті, визначте Impact у контексті знахідки пентесту. Поясніть, чим він відрізняється від Severity, а потім наведіть короткий приклад, де два різних клієнти мають однакову CVSS-оцінку та однаковий рівень впевненості, але зазнають дуже різного бізнес-впливу.

Завдання 1.2: Дослідження CVE-2011-2523 (8 балів)

Використовуючи опис, наданий викладачем, визначте тип вразливості CVE-2011-2523. Це buffer overflow, backdoor, injection чи misconfiguration? Опишіть механізм тригера конкретно: що саме відправляє атакуючий і що робить сервер у відповідь?

Вкажіть CVSS-оцінку та поясніть, чи це число говорить вам про серйозність, чи про ймовірність успішної експлуатації. Потім поясніть, чому цю вразливість класифікують як supply-chain compromise. Подумайте уважно: що саме було скомпрометовано: вихідний код, робоча станція розробника чи сервер розповсюдження?

Назвіть дві атаки з періоду 2020 по 2024 рік, що слідували подібному supply-chain паттерну, і коротко зазначте, що спільного вони мають з випадком vsftpd.

Завдання 1.3: Розрізнення інструменту та причини (6 балів)

Уявіть, що Metasploit ніколи не було створено. Чи був би vsftpd 2.3.4 все ще вразливим? Напишіть чітке пояснення, чому відповідь на це питання важлива для нашого розуміння експлуатації.

Опишіть ручний процес активації backdoor з використанням лише telnet. Пройдіть крок за кроком: які команди ви б набрали і що очікували б побачити на кожному етапі.

Доповніть наступне речення та поясніть свої міркування: «Metasploit це _____, а причина вразливості це _____.» Завершіть поясненням, чому ця відмінність має реальну вагу у професійному звіті пентесту.

Частина 2: Go/No-Go та керована експлуатація (Core) (25 балів, приблизно 30 хвилин)

Виконуйте кроки послідовно. Кожне завдання з терміналом потребує скріншоту з видимою командою та її виводом. Письмові пояснення тримайте в межах одного-двох речень, якщо завдання не просить більше.

Завдання 2.1: Заповнення Go/No-Go чек-листа (5 балів)

Перш ніж запускати що-небудь у Metasploit, заповніть Go/No-Go gate з Лекції 3. Для кожного з шести пунктів (в score, ціль підтверджена, версія підтверджена, очікувана поведінка зрозуміла, план доказів готовий, умова зупинки визначена) запишіть конкретний доказ. Наприклад, під пунктом «версія підтверджена» вкажіть точну команду Nmap та її вивід.

Потім дайте відповідь: якщо хоча б один пункт у чек-листі позначений «Ні», що ви повинні зробити? Одного речення достатньо.

Завдання 2.2: Перевірка цілі (3 бали)

Виконайте nmap -sV -p 21 192.168.56.101 і зробіть скріншот результату. Підтвердіть, що виявлена версія збігається з тією, що описує CVE-2011-2523.

Завдання 2.3: Пошук та налаштування exploit (5 балів)

Відкрийте msfconsole, знайдіть vsftpd, оберіть модуль backdoor і виконайте show options. Потім встановіть RHOSTS на 192.168.56.101 і знову виконайте show options. Зробіть скріншоти і результатів пошуку, і фінальних налаштованих параметрів.

Своїми словами поясніть, що означає RHOSTS. Потім подумайте, що станеться, якщо ви випадково встановите RHOSTS на неправильну IP-адресу. Які наслідки в лабораторному середовищі, і чим вони відрізнялися б у реальному завданні?

Завдання 2.4: Виконання exploit (7 балів)

Наберіть run і дайте exploit виконатися. Зробіть скріншот повного виводу. Цей скріншот є вашим основним доказом для звіту.

Перегляньте вивід та визначте, який рядок підтверджує активацію backdoor. Знайдіть рядок, що підтверджує наявність shell. Поясніть простою мовою, що означає uid=0(root) і який рівень доступу це надає в Unix-системі.

Завдання 2.5: Протокол мінімальних доказів (5 балів)

Тепер виконайте шестикроковий протокол доказів з Лекції 3. Запустіть whoami, потім id, потім uname -a, потім hostname. Зробіть скріншот, що включає всі чотири виводи разом з видимою часовою міткою. Після цього наберіть exit, щоб вийти з shell.

Коротко поясніть, чому протокол визначає саме ці команди, а не інші. Що було б втрачено для вашого звіту, якби ви пропустили, скажімо, hostname?

Після виходу запустіть nmap -sV -p 21 192.168.56.101 ще раз і зробіть скріншот. Це підтверджує, що ціль все ще працює після вашої експлуатації.

Частина 3: Аналіз та документування (Core) (15 балів, приблизно 20 хвилин)

Це, мабуть, найважливіша частина лабораторної. Експлуатація без належного документування не має професійної цінності. Знахідка, яку ви тут пишете, це продукт, який фактично отримав би клієнт.

Завдання 3.1: Побудова причинно-наслідкового ланцюга (5 балів)

Опишіть експлуатацію як причинно-наслідкову послідовність, а не як перелік кроків. Почніть з першопричини: що міститься у вихідному коді vsftpd, чого там не повинно бути? Потім поясніть тригер: яка конкретна дія користувача активує backdoor? Далі опишіть реакцію: що робить vsftpd у відповідь на тригер? Після цього вкажіть результат: який доступ отримує атакуючий?

Нарешті, зверніться до ролі Metasploit. Чи був він причиною вразливості, чи лише автоматизував процес, який можна було б виконати вручну? Пишіть одне-два речення на кожен рівень ланцюга.

Завдання 3.2: Написання професійної знахідки (10 балів)

Напишіть повну знахідку пентесту з усіма п'ятьма компонентами. У розділі Finding дайте професійну назву, що включає CVE-номер та задіяний сервіс. У розділі Evidence опишіть команду Metasploit, посилайтесь на ключовий рядок виводу та зазначте, що той самий результат відтворюється через telnet. У розділі Impact вийдіть за межі фрази «root shell» та опишіть, що атакуючий може реально зробити з цим доступом: подумайте про розкриття даних, модифікацію системи та потенціал латерального руху.

У розділі Confidence вкажіть, чи ваша знахідка Confirmed, Probable чи Needs Verification, і поясніть свій вибір. У розділі Recommendation надайте щонайменше чотири конкретних кроки. Не пишіть просто «оновити програмне забезпечення». Подумайте про негайне обмеження, видалення скомпрометованого пакету, перевстановлення з довіреного джерела, перевірку цілісності та перегляд процесу, який дозволив цьому пакету бути розгорнутим.

Пишіть всю знахідку так, ніби її читатиме СТО клієнта, якому потрібно прийняти бюджетне рішення на основі вашої оцінки.

Частина 4: Поглиблений аналіз (Advanced, необов'язково) (20 балів)

Ця частина доступна для студентів, які завершили Core із запасом часу.

Ця частина необов'язкова. Вона призначена для студентів із сильнішою технічною підготовкою. Невиконання Частини 4 не впливає на здачу лабораторної.

Завдання 4.1: Чому exploit може не спрацювати (6 балів)

На Лекції 3 ми обговорювали шість причин, чому exploit може не спрацювати, навіть коли все виглядає правильно. Пригадайте всі шість з пам'яті або з конспекту. Для кожної напишіть речення, як вона може конкретно стосуватися нашого сценарію з vsftpd.

Потім оберіть одну причину, яку вважаєте найімовірнішою у реальному завданні, не в лабораторії, і поясніть свої міркування. Що робить саме цей тип збою більш небезпечним або більш поширеним за інші?

Завдання 4.2: Ручна експлуатація без Metasploit (7 балів)

Відтворіть всю експлуатацію vsftpd використовуючи лише telnet. Підключіться до порту 21 на 192.168.56.101, відправте USER :) та PASS anything, потім відкрийте другий термінал і підключіться до порту 6200. Зробіть скріншот кожного кроку.

Порівняйте результат з виводом Metasploit. Чи отримали ви той самий uid? Що це говорить вам про зв'язок між інструментом автоматизації та базовою вразливістю? Опишіть сценарій у професійному завданні, де ви б свідомо обрали ручну експлуатацію замість Metasploit, і поясніть чому.

Завдання 4.3: Відображення лабораторної на фази PTES (7 балів)

Поверніться до лабораторної та відобразіть п'ять конкретних завдань на відповідні фази PTES. Завдання 1.2, CVE-дослідження, належить до однієї фази. Завдання 2.1, Go/No-Go чек-лист, до іншої. Завдання 2.4, виконання exploit, відповідає третій. Завдання 2.5, взаємодія з shell та збір доказів, четвертій. І Завдання 3.2, написання знахідки, п'ятій. Для кожного напишіть одне речення, чому саме ця фаза.

Потім поміркуйте над структурою курсу. Ми дійшли до фази 5 PTES лише на третьому тижні, після двох повних тижнів підготовки. Як ви думаєте, чому курс побудований саме так? Що було б втрачено, якби ми почали з експлуатації на першому ж занятті?

Частина 5: Аналітична глибина (PhD Extension, необов'язково) (20 балів)

Цей розділ розрахований на студентів магістратури та аспірантури. Може бути зданий протягом 48 годин після заняття.

Ця частина необов'язкова та призначена для PhD-студентів. Вимагає синтезу та критичної оцінки, що виходить за межі стандартних очікувань лабораторної.

Завдання 5.1: Застосування моделі Severity, Confidence, Impact (7 балів)

Розгляньте два сценарії. У Сценарії А vsftpd 2.3.4 працює на ізольованій лабораторній віртуальній машині без продакшн-даних. У Сценарії Б та сама версія vsftpd працює на файловому сервері клієнта, що зберігає фінансові записи клієнтів.

Оцініть Severity для обох. Чи однакова CVSS-оцінка? Повинна бути, але поясніть чому. Потім оцініть Confidence. Чи залежить рівень впевненості від середовища, чи він визначається виключно технічними доказами? Нарешті, оцініть Impact, і тут два сценарії повинні суттєво розійтися. Опишіть різницю бізнес-мовою, не лише технічними термінами.

Завершіть поясненням, як секція Recommendation вашої знахідки відрізнятиметься між двома сценаріями. Які додаткові кроки ви б включили для Сценарію Б, що були б зайвими для Сценарію А?

Завдання 5.2: Критика supply-chain виміру (7 балів)

Порівняйте три supply-chain атаки різних епох: vsftpd 2.3.4 у 2011, SolarWinds у 2020 та XZ Utils у 2024. Для кожного випадку визначте, що саме було скомпрометовано (сервер розповсюдження, pipeline збірки чи довіра мейнтейнера), як довго тривала компрометація до виявлення, і що робило виявлення особливо складним.

Тепер подумайте про виправлення. Коли пентестер виявляє, що сервер використовує ПЗ зі скомпрометованого supply-chain, стандартна порада — оновити до чистої версії. Поясніть, чому ця рекомендація сама по собі недостатня. Що ще повинен включати зрілий план виправлення?

Нарешті, подумайте, як supply-chain природа CVE-2011-2523 повинна змінити спосіб формулювання знахідки у звіті порівняно з простим buffer overflow. Яку мову ви б використали інакше, і чому формулювання має значення для клієнта?

Завдання 5.3: Етика та комунікація з клієнтом (6 балів)

Ваш колега пропонує: оскільки ви вже маєте root-доступ, спробуйте дістатися інших машин у внутрішній мережі, щоб продемонструвати потенціал латерального руху. Оцініть цю пропозицію уважно. За яких конкретних умов це було б прийнятно, і за яких умов це становило б порушення score? Обґрунтуйте відповідь через Score of Work та Go/No-Go framework з лекції.

Тепер змініть перспективу. СЕО клієнта запитує вас простою мовою, наскільки серйозною є знахідка на FTP. Напишіть відповідь приблизно 120 на 150 слів, яка пояснює знахідку, її бізнес-вплив, supply-chain вимір та ваш рекомендований наступний крок. Не використовуйте слова exploit, backdoor, root shell або CVE ніде у відповіді.

І ще одне. Молодший член команди пише у чернетці звіту: «Ми використали Metasploit для зламу сервера.» Перепишіть це речення так, щоб воно було технічно точним та професійно прийнятним, а потім поясніть у двох-трьох реченнях, чому оригінальне формулювання проблемне.

Критерії оцінювання

Компонент	Бали	Критерії
Частина 1: Поняття та CVE (Core)	20	Точність визначень CVE/CVSS/Impact, supply-chain мислення, інструмент проти причини
Частина 2: Go/No-Go та exploit (Core)	25	Повнота чек-листа, правильний workflow Metasploit, скріншоти, протокол доказів
Частина 3: Аналіз та документування (Core)	15	Точність причинно-наслідкового ланцюга, якість Finding (всі 5 компонентів)
Частина 4: Поглиблений (необов'язково)	20	Причини збою exploit, ручне відтворення, PTES фази
Частина 5: PhD (необов'язково)	20	Severity/Confidence/Impact, supply-chain критика, етика
Прохідний поріг	60	Частини 1 по 3 (Core) достатньо для здачі
Разом	100	

Інструкції з подання

Здайте роботу як один PDF-документ з назвою Lab3_Прізвище_Група.pdf. Усі скріншоти повинні бути розбірливими, показуючи повне вікно терміналу з чітко видимими командою та виводом.

Частини 1 по 3 потрібно виконати під час 90-хвилинної сесії. Частину 4 можна виконати під час сесії, якщо ви завершили Core раніше. Частина 5 може бути здана протягом тижня після завершення заняття.

Знахідка у Завданні 3.2 повинна містити всі п'ять компонентів. Неповні знахідки отримують часткові бали. Пізня здача Core оцінюється зі штрафом 10 відсотків за день, максимум три дні.